TRƯỜNG ĐẠI HỌC BÁCH KHOA TP. HỒ CHÍ MINH
KHOA KHOA HỌC VÀ KỸ THUẬT MÁY TÍNH




TOPIC PROPOSAL
MÔN: CÔNG NGHỆ PHẦN MỀM THẾ HỆ MỚI (CO5151)

---

# SECURE AGENTIC BI FRAMEWORK

---

**GVHD:** TS. Lê Xuân Bách
**HVTH:** Cao Nguyễn Minh Hiếu - 2470575
Nguyễn Hữu Lợi - 2470012
Nguyễn Công Thành - 2470744
Phạm Quỳnh Trân - 2470731

*TP. Hồ Chí Minh, 09/2026*

# Mục lục

**1 Tự đánh giá chất lượng đề tài (Topic-Quality Gate) 2**

**2 Bài toán & Người dùng mục tiêu 2**

2.1 Phát biểu bài toán . . . . . 2

2.2 Người dùng mục tiêu & Giá trị mang lại . . . . . 3

**3 Các hệ thống liên quan & Khoảng trống kỹ thuật 3**

**4 Giải pháp đề xuất & Các đóng góp kỹ thuật 3**

**5 Đánh giá định lượng & Kiểm chứng an toàn 4**

**6 Kế hoạch dự án, rủi ro & phương án dự phòng 5**

6.1 Kế hoạch dự án . . . . . 5

6.2 Rủi ro & Phạm vi dự phòng . . . . . 5

**7 Cam kết sử dụng AI (AI-Use Statement) 5**

# 1 Tự đánh giá chất lượng đề tài (Topic-Quality Gate)

- **Tính Mới (Novel):** Đề tài hướng tới xây dựng một Secure BI Agent cho phép truy vấn và phân tích dữ liệu bằng ngôn ngữ tự nhiên, đồng thời tích hợp bảo mật ngay trong quá trình Agent tương tác với dữ liệu. Điểm mới tập trung vào việc kết hợp kiểm soát quyền truy cập ở cấp truy vấn với cơ chế phát hiện và giảm thiểu Indirect Prompt Injection từ nội dung dữ liệu.
- **Tính Không Tầm Thường (Non-trivial):** Bài toán yêu cầu phối hợp nhiều khả năng của AI Agent, bao gồm lập kế hoạch, thực thi công cụ, tự kiểm tra và sửa lỗi, cùng các cơ chế kiểm soát an toàn cho SQL và môi trường phân tích dữ liệu.
- **Ý nghĩa (Meaningful):** Đề tài giải quyết một rào cản quan trọng khi doanh nghiệp triển khai các hệ thống "Chat with Data": làm thế nào để người dùng có thể khai thác dữ liệu thuận tiện mà không làm gia tăng nguy cơ truy cập trái phép, rò rỉ thông tin hoặc bị thao túng bởi dữ liệu độc hại.
- **Tính Khả Thi (Feasible):** Phạm vi nghiên cứu được giới hạn ở dữ liệu quan hệ và các tác vụ phân tích dữ liệu phổ biến. Nhóm sử dụng các framework và benchmark hiện có, kết hợp với các kịch bản kiểm thử bảo mật được xây dựng có kiểm soát.

# 2 Bài toán & Người dùng mục tiêu

## 2.1 Phát biểu bài toán

Các hệ thống BI truyền thống yêu cầu người dùng có kiến thức về SQL hoặc phải phụ thuộc vào đội ngũ kỹ thuật để truy xuất dữ liệu. LLM Agent có thể đơn giản hóa quá trình này bằng cách chuyển đổi yêu cầu ngôn ngữ tự nhiên thành truy vấn và thực hiện các tác vụ phân tích.

Tuy nhiên, việc cho phép Agent tương tác trực tiếp với dữ liệu doanh nghiệp tạo ra hai vấn đề quan trọng. Thứ nhất, Agent có thể truy cập nhiều dữ liệu hơn mức cần thiết nếu không có cơ chế phân quyền phù hợp. Thứ hai, nội dung dữ liệu do người dùng hoặc hệ thống bên ngoài tạo ra có thể chứa các chỉ thị độc hại, dẫn đến Indirect Prompt Injection khi được đưa vào context của Agent.

Do đó, bài toán của đề tài là xây dựng một hệ thống BI Agent vừa hỗ trợ truy vấn và phân tích dữ liệu bằng ngôn ngữ tự nhiên, vừa có khả năng kiểm soát quyền truy cập và bảo vệ Agent trước các rủi ro bảo mật phát sinh từ dữ liệu.

### 2.2 Người dùng mục tiêu & Giá trị mang lại

- **Data Analysts:** Có thể khám phá và phân tích dữ liệu nhanh hơn thông qua ngôn ngữ tự nhiên mà không cần viết toàn bộ truy vấn thủ công.
- **Business Users:** Có thể tự chủ thực hiện các truy vấn và phân tích nghiệp vụ cơ bản mà giảm phụ thuộc vào đội ngũ kỹ thuật.
- **SecOps/DBAs:** Có một lớp kiểm soát tập trung để đảm bảo Agent tuân thủ chính sách truy cập và giảm thiểu các rủi ro khi kết nối AI với dữ liệu doanh nghiệp.

## 3 Các hệ thống liên quan & Khoảng trống kỹ thuật

Các hệ thống Text-to-SQL và Data Agent hiện nay đã cho phép người dùng tương tác với cơ sở dữ liệu bằng ngôn ngữ tự nhiên và thực hiện các tác vụ phân tích phức tạp. Các nghiên cứu về Agent Security cũng đã đề xuất nhiều phương pháp nhằm phát hiện prompt injection và kiểm soát hành vi của Agent.

Tuy nhiên, các hướng tiếp cận này thường tập trung riêng vào khả năng phân tích dữ liệu hoặc bảo mật Agent. Các hệ thống BI Agent phổ biến chưa giải quyết đầy đủ trường hợp Agent vừa cần truy cập dữ liệu doanh nghiệp theo quyền hạn của người dùng, vừa phải đối phó với các chỉ thị độc hại nằm trong chính nội dung dữ liệu được truy xuất.

**Khoảng trống kỹ thuật (Gap):** Đề tài tập trung vào việc kết hợp khả năng phân tích dữ liệu bằng ngôn ngữ tự nhiên với các cơ chế bảo mật dành riêng cho môi trường BI, đặc biệt là kiểm soát quyền truy cập và giảm thiểu Indirect Prompt Injection từ dữ liệu.

## 4 Giải pháp đề xuất & Các đóng góp kỹ thuật

Đề tài đề xuất một **Secure Multi-Agent BI Framework**, trong đó các Agent chuyên biệt phối hợp để xử lý yêu cầu của người dùng, trong khi các tương tác với dữ liệu được kiểm soát bởi một lớp bảo mật trung gian.

Hệ thống tập trung vào bốn đóng góp chính:

1. **Secure Data Access:** Áp dụng nguyên tắc Least Privilege để đảm bảo Agent chỉ có thể truy cập dữ liệu phù hợp với vai trò và yêu cầu hiện tại của người dùng.

2. **SQL-level Security:** Phân tích và kiểm tra các truy vấn trước khi thực thi nhằm ngăn chặn các thao tác hoặc truy cập vượt quá chính sách cho phép.

3. **Protection against Indirect Prompt Injection:** Kiểm tra nội dung dữ liệu được truy xuất trước khi đưa trở lại context của Agent, nhằm giảm khả năng dữ liệu độc hại thao túng quá trình suy luận.

4. **Reliable Agent Execution:** Kết hợp planning, reasoning, tool execution và self-correction để Agent có thể xử lý các tác vụ phân tích nhiều bước và phục hồi khi một thao tác bị từ chối hoặc thất bại.

Các cơ chế trên được thiết kế theo hướng tách biệt giữa khả năng suy luận của Agent và quyền thực thi thực tế, qua đó giảm tác động khi Agent sinh ra truy vấn sai hoặc bị thao túng.

# 5 Đánh giá định lượng & Kiểm chứng an toàn

Nhóm sẽ xây dựng một tập tác vụ gồm cả **functional tasks** và **security/adversarial tasks**. Functional tasks đánh giá khả năng thực hiện các yêu cầu phân tích dữ liệu từ đơn giản đến phức tạp, trong khi security tasks kiểm tra khả năng chống lại prompt injection, truy cập vượt quyền và các hành vi thực thi không an toàn.

Các chỉ số đánh giá chính gồm:

- **Utility:** Độ chính xác của kết quả và khả năng hoàn thành tác vụ.
- **Security:** Khả năng ngăn chặn các cuộc tấn công và duy trì đúng phạm vi quyền truy cập.
- **Efficiency:** Độ trễ và chi phí thực thi.

Nhóm cũng thực hiện **ablation study** để so sánh hệ thống đề xuất với các cấu hình đơn giản hơn. Mục tiêu là xác định mức đóng góp của lớp bảo mật và kiến trúc Multi-Agent đối với độ chính xác, khả năng chống tấn công và hiệu năng.

Bên cạnh đánh giá định lượng, nhóm sẽ thực hiện security walkthrough và red-team testing với các kịch bản đại diện cho người dùng thông thường, người dùng vô tình vượt quyền và kẻ tấn công cố ý. Kết quả sẽ được sử dụng để kiểm chứng cả tính hữu ích và khả năng bảo vệ của hệ thống trong các tình huống thực tế.

# 6 Kế hoạch dự án, rủi ro & phương án dự phòng

## 6.1 Kế hoạch dự án

| Giai đoạn | Mục tiêu chính | Deliverable |
|---|---|---|
| W1–W2 | Hoàn thiện proposal, nghiên cứu tài liệu và xác định phạm vi hệ thống. | D1 |
| W3–W5 | Xây dựng prototype BI Agent và các cơ chế kiểm soát truy cập cơ bản. | Prototype |
| W6–W7 | Tích hợp các cơ chế bảo mật và hoàn thiện luồng end-to-end. | D2 |
| W8–W9 | Xây dựng task set, security tests và thực hiện đánh giá định lượng. | Evaluation |
| W10–W11 | Red-team testing, kiểm chứng với người dùng và hoàn thiện hệ thống. | Final System |
| W12–W13 | Hoàn thiện báo cáo, tài liệu và chuẩn bị bảo vệ. | D3/D4 |

Bảng 1: Project timeline.

## 6.2 Rủi ro & Phạm vi dự phòng

- **Độ phức tạp của Agent hoặc chi phí thực thi vượt dự kiến:** Ưu tiên các tác vụ phân tích cốt lõi và giảm phạm vi các tính năng nâng cao nếu cần.
- **Khó khăn trong việc xây dựng môi trường thực thi an toàn:** Sử dụng cơ chế isolation đơn giản hơn làm fallback, trong khi vẫn đảm bảo các nguyên tắc bảo mật cốt lõi.
- **Khó khăn trong việc thu thập dữ liệu thực tế:** Sử dụng benchmark và synthetic datasets để đảm bảo khả năng đánh giá trong phạm vi dự án.

# 7 Cam kết sử dụng AI (AI-Use Statement)

AI được sử dụng như một công cụ hỗ trợ nhóm trong quá trình nghiên cứu tài liệu, phát triển ý tưởng, lập kế hoạch và hỗ trợ lập luận kỹ thuật. Các quyết định về bài toán, đóng góp, phương pháp đánh giá và thiết kế hệ thống đều được các thành viên trong nhóm rà soát và chịu trách nhiệm. Nhóm đảm bảo việc sử dụng AI tuân thủ các quy định của môn học.

# Tài liệu tham khảo

[1] Tao Yu, Rui Zhang, Kai Yang, Michihiro Yasunaga, Dongxu Wang, Zifan Li, James Ma, Irene Li, Qingning Zhou, Xiangru Tang, et al. Spider: A large-scale human-labeled dataset for complex and cross-domain semantic parsing and text-to-SQL tasks. In *Proceedings of the 2018 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pages 3911–3921, 2018.

[2] Jinyang Li, Binyuan Hui, Ge Qu, Jiaxi Yang, Binhua Li, Bowen Li, Bailin Wang, Bowen Qin, Rongyu Cao, Ruiying Geng, et al. Can LLM already serve as a database interface? A big bench for large-scale database-grounded text-to-SQLs (BIRD). In *Advances in Neural Information Processing Systems (NeurIPS)*, 36, 2024.

[3] Sirui Li, Guanting Chen, Yilun Zhao, Chen Qian, et al. Data-Interpreter: An LLM agent for data science. In *arXiv preprint arXiv:2402.18679*, 2024.

[4] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. ReAct: Synergizing reasoning and acting in language models. In *International Conference on Learning Representations (ICLR)*, 2023.

[5] Noah Shinn, Federico Cassano, Edward Berman, Ashwin Gopinath, Karthik Narasimhan, and Shunyu Yao. Reflexion: Language agents with verbal reinforcement learning. In *Advances in Neural Information Processing Systems (NeurIPS)*, 36, 2023.

[6] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, pages 79–90, 2023.

[7] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment for benchmarking agent security. In *arXiv preprint arXiv:2406.13352*, 2024.

[8] Luca Beurer-Kellner, Marc Fischer, and Martin Vechev. CaMeL: Context-aware policy enforcement for LLM agents via taint tracking. In *arXiv preprint arXiv:2409.12345*, 2024.